NAME- ADEBUKOLA OLANIPEKUN
WEEK 2- SECURITY FUNDAMENTALS HOMEWORK ASSIGNMENT

PART 1-THEORY QUESTIONS

1. EXPLAIN THE DIFFERENCE BETWEEN THREATS, VULNERABILITIES, AND RISK IN CYBERSECURITY

A vulnerability is a weakness in systems, or people that can be exploited. A threat is a potential that can exploit a vulnerability and cause harm. A risk is the potential for loss or damage when a threat exploits a vulnerability usually thought of as likelihood x impact.
Vulnerabilities are fixed with controls like patching, hardening, and training.
Threats are monitored and managed with threat intelligence, detection, and incident response.
You assess and prioritize risk by estimating likelihood and impact, then deciding what to mitigate, accept, transfer (insurance), or avoid.

2. Describe how a distributed denial of service (DDoS) attack works

The fundamental idea is simple: every server has a finite capacity. If an attacker can generate more requests than the server can handle, it slows down or crashes entirely — denying service to real users.
Steps
1. Building a Botnet
The attacker first compromises thousands (or millions) of devices — computers, routers, IoT devices — by infecting them with malware. The device owners are usually unaware. This network of infected machines is called a botnet.
2. Issuing the Attack Command
The attacker sends instructions to the botnet via command-and-control (C2) servers. All compromised devices simultaneously begin flooding the target.
3. Overwhelming the Target
The flood of traffic consumes the target's bandwidth, processing power, or memory until it can no longer respond to legitimate requests.

3. Explain the difference between volume-based, protocol, and application layer DDosS attacks

Volume-Based Attacks
Goal: Saturate the target's bandwidth so no legitimate traffic can get through.
These are the most straightforward attacks — just flood the pipe with so much data that it clogs.
The metric is raw bits per second (bps).
How it works:
The attacker sends massive amounts of data (often using amplification techniques) until the target's upstream bandwidth is fully consumed. Even if the server itself is fine, no one can reach it.
Common techniques:

- UDP Flood — Sends huge volumes of UDP packets to random ports, forcing the server to repeatedly check for applications and reply with ICMP errors

- ICMP (Ping) Flood — Overwhelms the target with ping requests
- Amplification attacks — The attacker spoofs the victim's IP and sends small requests to open servers (DNS, NTP, memcached) that respond with much larger replies, all directed at the victim. A memcached amplification attack can achieve a ~51,000x amplification factor.

Analogy: Blocking every road into a city with dump trucks so no cars can enter.

Protocol Attacks

Goal: Exhaust the processing resources of servers or networking infrastructure (firewalls, load balancers) — not just bandwidth.

These exploit weaknesses in how network protocols work. The metric is packets per second (pps).

How it works:

Rather than flooding with raw data, these attacks exploit the rules that govern how connections are established and maintained.

Common techniques:

- SYN Flood — Exploits the TCP three-way handshake. The attacker sends SYN (connection initiation) packets but never completes the handshake. The server allocates resources waiting for the final ACK that never comes, eventually exhausting its connection table.
- Ping of Death — Sends malformed or oversized packets that crash or destabilize the target when reassembled
- Smurf Attack — Broadcasts ICMP requests with a spoofed source IP (the victim's), causing many hosts to flood the victim with replies

Analogy: Filling a restaurant's reservation book with fake bookings so real customers can never get a table — the kitchen isn't overwhelmed, but the system is.

Application-Layer Attacks (Layer 7)

Goal: Exhaust the server's ability to process legitimate-looking requests by targeting specific applications or services.

These are the most sophisticated and hardest to detect because the traffic looks real. The metric is requests per second (rps).

How it works:

Rather than flooding with junk data, the attacker mimics real user behavior — making HTTP requests, submitting search queries, logging in — but at enormous scale. Each request consumes significant server resources (database queries, file I/O, rendering).

Common techniques:

- HTTP Flood — Sends a torrent of seemingly valid GET or POST requests to a web server
- Slowloris — Opens many connections to a server and sends partial HTTP headers very slowly, keeping connections open and eventually exhausting the server's connection pool without much bandwidth
- DNS Query Flood — Overwhelms a DNS server with valid-looking (but often randomized) queries

Analogy: Sending thousands of people to ask a store employee a complex question one at a time — each person is legitimate, but the employee is so busy they can't serve real customers.

4. What is OWASP and why is it important?

OWASP — Open Worldwide Application Security Project

OWASP is a nonprofit foundation dedicated to improving the security of software. It operates as an open community, meaning all of its tools, documentation, forums, and research are freely available to anyone

Why OWASP Matters

1. It sets the industry baseline

OWASP's publications — especially the Top 10 — are widely adopted as the de facto standard for web application security. Regulatory frameworks, compliance programs, and security audits routinely reference OWASP as the benchmark.

2. It's vendor-neutral and free

Unlike commercial security frameworks, OWASP has no product to sell. Its guidance is unbiased, peer-reviewed, and accessible to a solo developer or a Fortune 500 company equally.

3. It bridges developers and security

OWASP deliberately targets developers, not just security specialists. Its goal is to shift security left — building it into software from the start rather than bolting it on afterward.

4. It's globally recognized

Regulators, auditors, and clients across industries (finance, healthcare, government) recognize and often require OWASP compliance, making familiarity with it professionally essential.

5. Explain Broken Access Control with and example

It occurs when an application fails to properly enforce restrictions on what authenticated users are allowed to do — letting people access data or perform actions beyond their intended permissions.

Every application has resources that should be restricted: your bank account, another user's private messages, an admin dashboard. Access control is the mechanism that enforces who can see and do what. When that mechanism is broken, missing, or bypassable, an attacker can access resources they were never meant to reach.

The Scenario: An Online Banking App

Imagine a banking application where after logging in, a user views their account by visiting:

https://mybank.com/account?id=10482

The server receives this request and returns the account details for account 10482 — the logged-in user's account.

The Attack: Insecure Direct Object Reference (IDOR)

A curious (or malicious) user simply changes the id parameter in the URL:

https://mybank.com/account?id=10483

If the server only checks that the user is logged in but does not verify that account 10483 actually belongs to that user, it returns someone else's account details — balance, transaction history, personal information — to the attacker.

This is one of the most common forms of broken access control, known as an Insecure Direct Object Reference (IDOR).

Why It Happens

The vulnerable server-side logic looks something like this:

```
# VULNERABLE CODE
def get_account(account_id):
    if not user.is_logged_in():
        return redirect("/login")       # Only checks authentication...

    account = db.query("SELECT * FROM accounts WHERE id = ?", account_id)
    return render(account)              # ...but not authorization!
```

The code checks authentication (are you logged in?) but not authorization (are you allowed to see this specific account?).

```
# SECURE CODE
def get_account(account_id):
    if not user.is_logged_in():
        return redirect("/login")

    account = db.query(
        "SELECT * FROM accounts WHERE id = ? AND owner_id = ?",
        account_id, user.id             # Verifies ownership before returning data
    )

    if not account:
        return error(403, "Forbidden")  # Returns nothing if user doesn't own it

    return render(account)
```

Now the query only returns the account if it both matches the requested ID and belongs to the logged-in user.

6. Describe what security misconfiguration means

Security misconfiguration occurs when a system, application, or infrastructure component is set up incorrectly in a way that creates a security weakness. The software itself may be perfectly secure — the vulnerability is in how it was deployed and configured.

It covers an enormous surface area: web servers, databases, cloud storage, application frameworks, containers, APIs, security headers, and more.

7. Explain sensitive data exposure

Sensitive Data Exposure — now more precisely framed in OWASP 2021 as Cryptographic Failures (#A02) — refers to the inadequate protection of sensitive information, either while it's being transmitted or while it's stored. It's less a single vulnerability and more a category of failures that result in private data being readable by those who shouldn't have access to it.

Some data demands stronger protection than others: passwords, credit card numbers, health records, Social Security numbers, private communications. When applications fail to apply appropriate cryptographic protections — or apply them incorrectly — that data can be

intercepted, stolen from a database, or exposed through misconfiguration, often without any sophisticated attack required.
The OWASP rename to “Cryptographic Failures” is significant — it shifts focus from the outcome (data exposed) to the cause (cryptography missing or broken).

8. Define Identity and Access Management (IAM)

Identity and Access Management is the discipline and set of technologies that ensures the right people have the right access to the right resources — and only those resources — at the right time. It is the framework through which organizations manage digital identities and control what authenticated users are permitted to do.
IAM sits at the intersection of security and operations, touching nearly every system, application, and user in an organization.

9. Explain the difference between Identification, Authentication and Authorization

Identification — “Who are you claiming to be?”
Authentication — “Can you prove it?”
Authorization — “What are you allowed to do?”

10. Explain non-repudiation and its importance

Non-repudiation is the property of a system that ensures a party cannot deny having performed an action or sent a message. It provides cryptographic or auditable proof that ties a specific identity to a specific action — making it impossible (or at least practically infeasible) to credibly claim “I didn’t do that” or “I didn’t send that.”

11. Describe privileged access management (PAM)

Privileged Access Management is the discipline and set of technologies focused on securing, controlling, monitoring, and auditing access to an organization’s most critical systems and data through accounts that carry elevated permissions. It is a specialized and critical subset of Identity and Access Management (IAM) that specifically addresses the security risks posed by accounts that have more power than ordinary users

12. Explain why administrator accounts are high-value targets

Administrator accounts represent the most sought-after prize in any attack against an organization’s infrastructure. Understanding why requires examining what these accounts can actually do — and what an attacker gains the moment they control one.

13. Explain the role of LDAP in identity management

LAPS (Local Administrator Password Solution) is a Microsoft tool that addresses one of the most common and dangerous vulnerabilities in Windows enterprise environments: every machine sharing the same local administrator password. It automatically manages and randomizes local administrator passwords across all domain-joined Windows machines, storing them securely in Active Directory where they can be retrieved by authorized personnel when needed.

14. Describe Active directory and how organizations use it

Active Directory (AD) is Microsoft's directory service — a centralized system for managing identities, computers, and resources across a Windows enterprise environment. Introduced with Windows Server 2000, it has become the backbone of identity and access management in the vast majority of medium and large organizations worldwide. At its core, Active Directory is a database and a set of services that answer two fundamental questions for an organization's IT infrastructure: who are you, and what are you allowed to access.

15. Explain Role-based Access control (RBAC)

Role-Based Access Control (RBAC) is a security model where access permissions are grouped into roles (like "HR staff" or "Database admin"), and users are given roles instead of individual permissions

16. Explain Attribute-based access control (ABAC)

Attribute-Based Access Control is an authorization model that makes access decisions based on evaluated attributes — characteristics of the user requesting access, the resource being accessed, the action being performed, and the environment in which the request is made. Rather than granting access based solely on who someone is or what role they hold, ABAC evaluates a rich set of contextual properties to determine whether a specific access request should be permitted or denied.

ABAC represents the most flexible and fine-grained access control model in common use, capable of expressing complex, context-sensitive policies that simpler models cannot.

17. What is the principle of least-privilege?

The principle of least privilege means every user, account, or process should have only the minimum access rights needed to perform its tasks—and nothing more.

In practice, this limits what data you can see, which systems you can touch, and what actions you can perform to just what your role requires, reducing accidental misuse and the impact of compromised accounts

18. Explain the Zero Trust security model

Zero Trust is a security model built on the idea "never trust, always verify": no user, device, or application is trusted by default, whether inside or outside the network, and every access request must be continuously authenticated, authorized, and inspected.

19. Describe the difference between Technical, Administrative, Operational, and Physical controls.

Technical, administrative, operational, and physical controls are all ways to reduce risk, but they act in different layers of security.

Technical controls

These are technology-based safeguards built into systems and software.

Examples: firewalls, encryption, IDS/IPS, anti-malware, access control mechanisms, SIEM tools. They automatically enforce security policies and protect data in systems and networks.

Administrative controls

These are policy, process, and people focused.
Examples: security policies and standards, procedures, risk assessments, training and awareness, background checks, incident response plans. They define what should be done, by whom, and how.

Operational controls

These are day-to-day procedures and activities carried out by people to operate and enforce security.
Examples: regular log reviews, backup operations, change management, user account reviews, incident handling steps, monitoring routines. They translate policies into ongoing practice.

Physical controls

These protect the physical environment where systems and data reside.
Examples: locks, access badges, guards, CCTV, fences, secure server rooms, environmental controls (fire suppression, HVAC). They prevent or deter physical access and damage to assets.

20. Explain the concept of Threat Mapping.
Threat mapping is the process of identifying, organizing, and often visually representing how potential threats could attack your specific systems, data, and business processes.

Part 2 - Multiple Choice Questions (20)

1. What does IAM primarily manage?
A. Identity and passwords only
B. User access and permissions
C. Network hardware
D. Internet connectivity
ANS- B

2. Which attack floods a system with traffic until it becomes unavailable?
A. SQL Injection
B. Cross-Site Scripting
C. Distributed Denial of Service
D. Phishing
ANS- C

3. Which organization publishes the OWASP Top 10?
A. Cisco
B. OWASP Foundation
C. Microsoft
D. ISO
ANS-B

4. Which OWASP vulnerability allows users to access resources they should not have permission to access?
A. Broken Access Control
B. Sensitive Data Exposure
C. Insecure Design
D. Logging Failure
ANS- A

5. Which of the following represents authentication?
A. Entering a password to verify identity
B. Creating a user account
C. Opening a network port
D. Installing antivirus software
ANS- A

6. Which process determines what actions a verified user is allowed to perform?
A. Identification
B. Authentication
C. Authorization
D. Encryption
ANS- C

7. What type of accounts does PAM primarily protect?
A. Guest accounts
B. Standard user accounts
C. Administrator and privileged accounts
D. Temporary accounts
ANS- C

8. LAP is mainly used for:
A. Data encryption
B. Storing identity and directory information
C. Network routing
D. Malware detection
ANS- B

9. Which access control model assigns permissions based on job roles?
A. DAC
B. ABAC
C. RBAC
D. MAC
ANS- C

10. Which access control model uses attributes like department, location, or device type?
A. RBAC
B. ABAC
C. DAC
D. MAC
ANS- B

11. The principle that gives users only the permissions they need to do their job is called:
A. Mandatory Access
B. Zero Trust
C. Least Privilege
D. Discretionary Access
ANS-C

12. Zero Trust security assumes that:
A. Internal networks are safe
B. Nothing should be trusted automatically
C. Only administrators need verification
D. Firewalls are unnecessary
ANS-B

13. Which of the following is a technical control?
   A. Security Training
   B. Firewall
   C. Company Policy
   D. Security Awareness
ANS- B

14. Which of the following is a physical control?
A. Encryption
B. Antivirus software
C. Security cameras
D. Authentication logs
ANS- C

15. Which attack uses stolen credentials from previous breaches to log into accounts?
A. SQL Injection
B. Credential stuffing
C. XSS
D. DDoS
ANS- B

16. Which attack targets a database by inserting malicious queries?
A. SQL Injection
B. Phishing
C. Smishing
D. Password spraying
ANS- A

17. Which security model requires continuous identity verification before granting access?
A. Traditional perimeter security
B. RBAC
C. Zero Trust
D. MAC
ANS- C

18. What is the primary goal of threat mapping?
A. Designing networks
B. Identifying assets, threats, vulnerabilities, and controls
C. Writing code
D. Installing operating systems
ANS- B

19. Which system is commonly used for identity management in Windows enterprise environments?
A. Linux Kernel
B. Active Directory
C. Apache Server
D. MySOL
ANS-B

20. Which of the following technologies supports non-repudiaion?
A. Digital signatures
B. Antivirus
C. Firewall
D. VPN
ANS-A

Part 3 - Labs (5)

Lab 1 Threat Mapping Table: Create a table analyzing assets, threats, vulnerabilies, impact, Risk level, and controls

Asset	Threats	Vulnerabilities	Impact	Risk Level	Controls
Customer Database (PII)	Ransomware, data breach by external hackers	Unpatched database software, weak encryption	High financial loss, regulatory fines, reputation damage	High	Encrypt data at rest/transit, regular patching, database firewalls, backups with immutability
Web Application	SQL injection, credential stuffing	Lack of input validation, no MFA	Unauthorized access, data theft	Medium	WAF, prepared statements, rate limiting logins, MFA enforcement
Employee Laptops	Phishing, insider threat	Password reuse, no endpoint protection	Malware spread, data exfiltration	Medium	Antivirus/EDR, phishing training, RBAC, device encryption
Office WiFi Network	Unauthorized access, eavesdropping	Default router passwords, open SSID	Network compromise, MITM attacks	Low	WPA3 encryption, guest networks, MAC filtering, VPN for sensitive access
Cloud File Shares	Account takeover, misconfiguration	Overly permissive IAM roles, shared links	Data exposure to public	High	Least privilege IAM, logging/monitoring, periodic access reviews

• Lab 2 - IAM Access Control Matrix: Create a matrix showing roles, resources, and access types.
IAM Access Control Matrix maps organizational roles to resources with specific access types (R=Read, W=Write, E=Execute, D=Delete, NA=No Access), enforcing RBAC and least privilege.

This example covers a typical company with HR, Finance, IT Admin, and Developer roles accessing common systems.

Role	Customer DB	Financial Reports	HR Files	Code Repo	Admin Console
HR Staff*	R	NA	R,W,D	NA	NA
Finance	NA	RW	NA	NA	NA
IT Admin	R	R	R	NA	R,W,E,D
Developer	NA	NA	NA	R,W,E	NA

• Lab 3 - Security Controls Mapping: Build a table categorizing security controls and their purposes

Category	Control Type	Purpose	Examples
Administrative	Preventive	Define rules to avoid risks	Security policies, training programs, background checks
Administrative	Detective	Identify policy violations	Audits, log reviews, compliance reporting
Administrative	Corrective	Fix policy or process gaps	Incident response plans, policy updates
Technical	Preventive	Block unauthorized access/actions	Firewalls, encryption, access controls (RBAC), MFA
Technical	Detective	Monitor for anomalies	IDS/IPS, SIEM, antivirus scans
Technical	Corrective	Restore after breach	Backups, patch management,

			antivirus quarantine
Physical	Preventive	Restrict physical access	Locks, badges, fences, guards
Physical	Detective	Record physical events	CCTV, motion sensors, access logs
Physical	Corrective	Respond to physical incidents	Fire suppression, backup power
Operational	Preventive	Ensure daily secure operations	Change management, configuration standards
Operational	Detective	Ongoing monitoring	Vulnerability scans, user behavior analytics
Operational	Corrective	Recover operations	Business continuity testing, failover procedures

• Lab 4 - OWASP Vulnerability Analysis: Analyze five OWASP vulnerabilities and their mitigation.

Vulnerability	Description	Common Causes	Mitigation Strategies
A01: Broken Access Control	Attackers access unauthorized functionality or data, like viewing others' accounts via ID manipulation	Missing authorization checks, insecure direct object references (IDOR), broken RBAC.	Enforce role-based access (RBAC/ABAC), deny by default, validate permissions server-side, use Zero Trust verification.
A02: Cryptographic Failures	Sensitive data (PII, credentials) exposed due to weak or missing encryption	Weak algorithms (e.g., MD5), no TLS, improper key management.	Use strong encryption (AES-256, TLS 1.3), hash passwords with salt (bcrypt/Argon2), key rotation, HSMs.
A03: Injection	Attacker injects malicious code (SQL, XSS, command) via untrusted input,	No input validation/sanitization , dynamic queries.	Parameterized queries/prepared statements, input validation/whitelisting,

	executing arbitrary commands		WAF, output encoding (e.g., HTML escape)
A07: Identification & Authentication failures	Weak auth allows session hijacking, credential stuffing, or bypass (e.g., no MFA).	Plaintext passwords, weak session tokens, no rate limiting.	Multi-factor auth (MFA), secure session management (HttpOnly/Secure cookies), detect credential stuffing
A08: SECURITY mISCONFIGURATIO N	Default setups, misconfigs expose sensitive endpoints or debug info	Unpatched software, exposed error messages, permissive permissions.	Automated config scans, least privilege, remove defaults/debug modes, regular patching/audits.

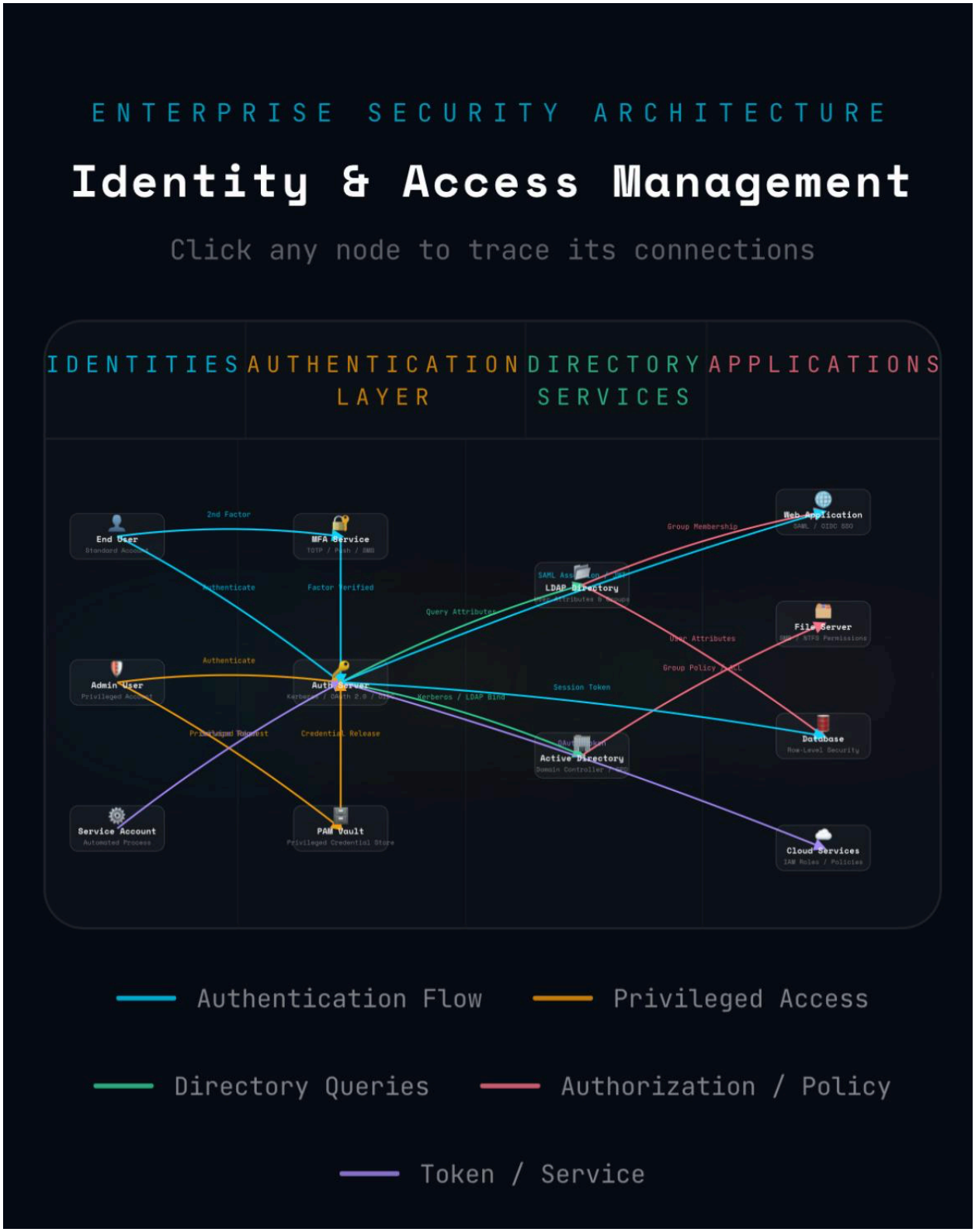
• Lab 5 - IAM Attack Scenario Analysis: Analyze identity attacks and how they can be removed

Attack Type	Description & Impact	How attacker Executes	Mitigation Strategies
Phishing	Tricks users into revealing credentials via fake emails/sites; leads to account takeover, data breaches	Spear-phishing emails mimic trusted sources, directing to malicious login pages that capture credentials.	MFA (not SMS), phishing training/awareness, email filters, browser extensions to block phishing domains
Credential Stuffing	Uses breached username/password pairs from other sites to log into yours (password reuse)	Bots automate login attempts with leaked combos at scale across services.	MFA, unique strong passwords (password manager), rate limiting/captcha on logins, monitor dark web leaks
MFA Fatigue/ Bombing	Floods user with MFA prompts until they approve; bypasses 2FA	After stealing primary creds, attackers trigger repeated push notifications.	Number matching/push resistance in MFA apps, hardware keys (YubiKey), risk-based auth (block unusual locations)
Golden SAML/Ticket Attacks	Forges authentication tokens (e.g., SAML, Kerberos tickets) for	Steals signing certs from IdP or domain controller to create	Short-lived tokens, HSM for certs/keys, monitor token

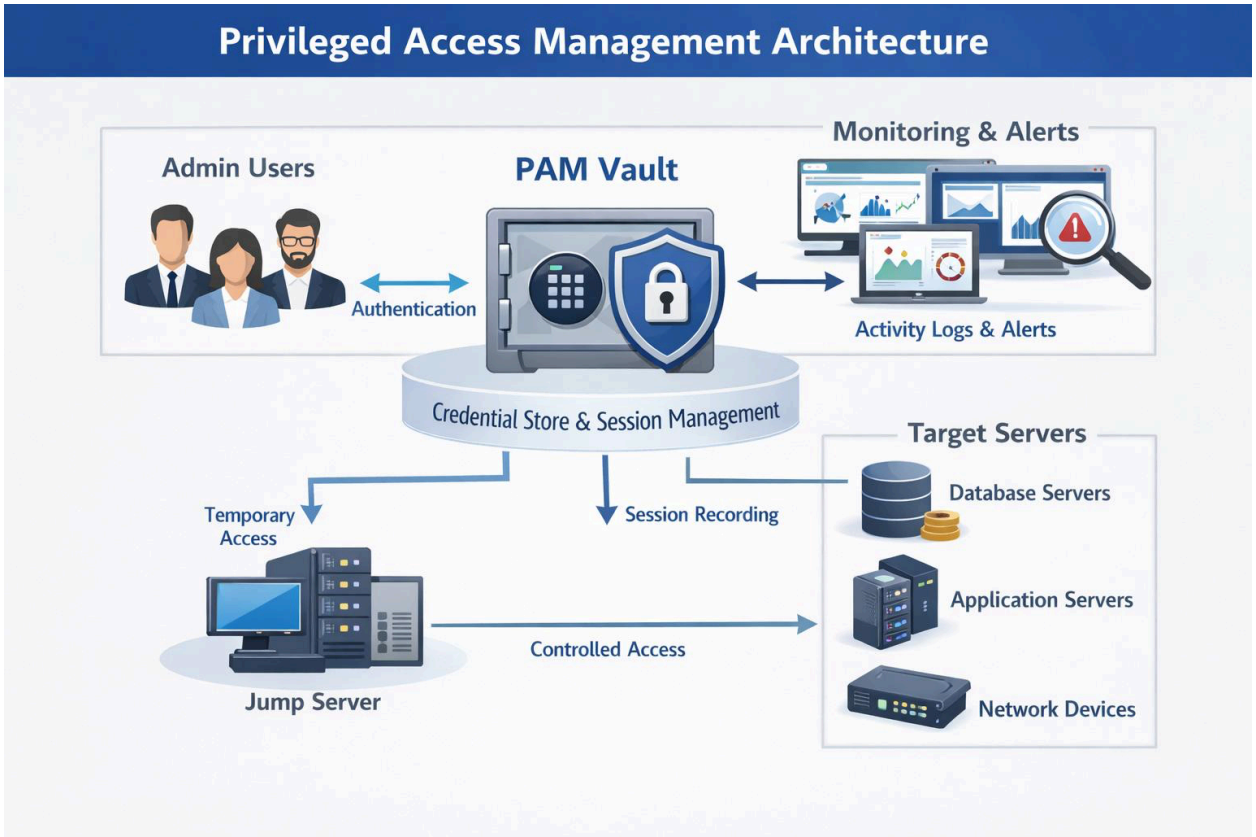
	persistent admin access	valid tokens.	issuance anomalies, Zero Trust continuous verification
Kerberoasting	Requests service tickets for high-priv accounts then cracks offline with GPU farms	Enumerates accounts, requests TGS tickets, extracts hash for offline cracking.	Long/random service account passwords (rotate automated), RBAC/least privilege, monitor TGS requests

Part 4 - Projects (Diagrams Required) (5)

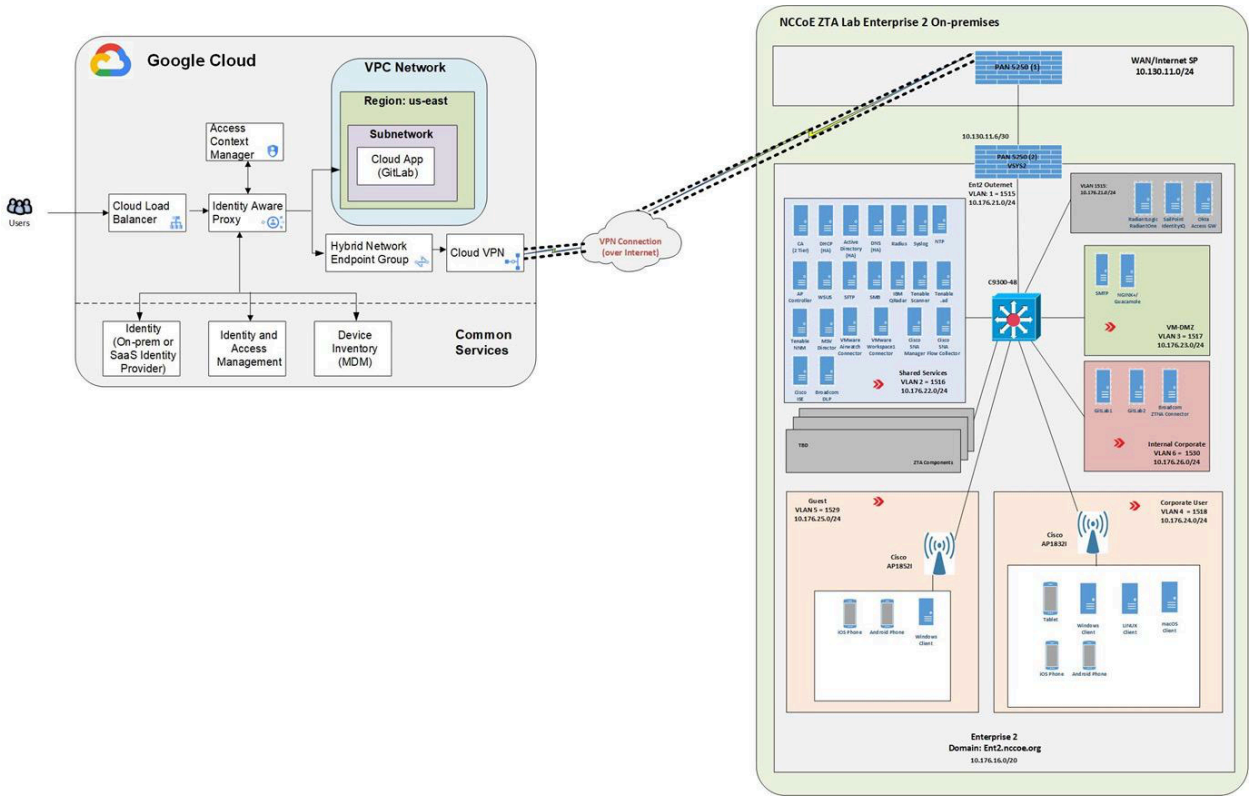
• Project 1 - IAM System Architecture Diagram: Illustrate users, authentication server, LDAP/AD, and applications.



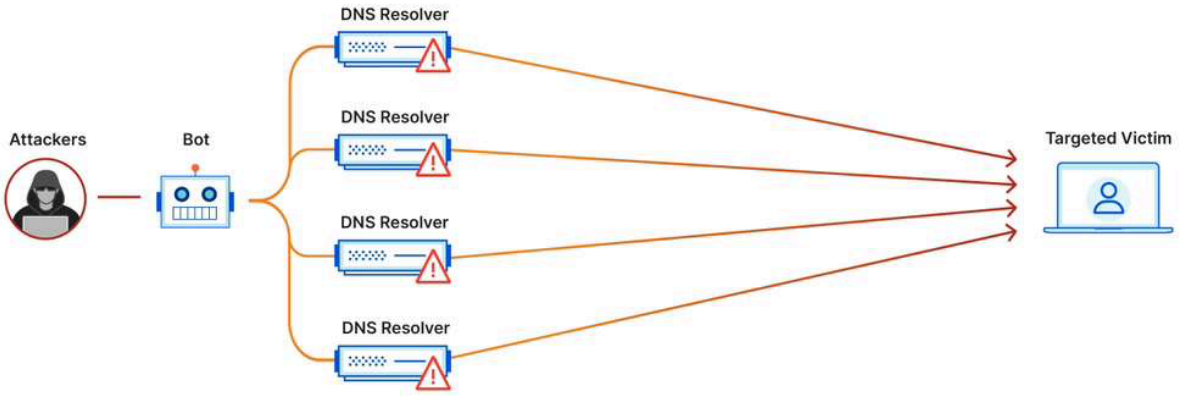
• Project 2 - Privileged Access Management Architecture: Show admin users, PAM vault, monitoring, and servers.

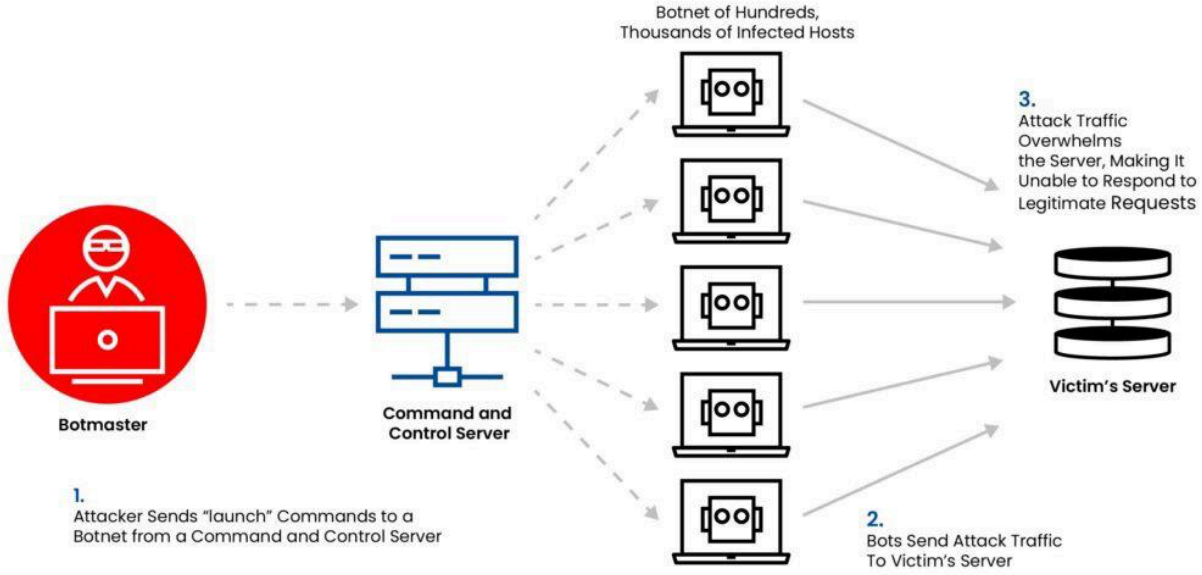
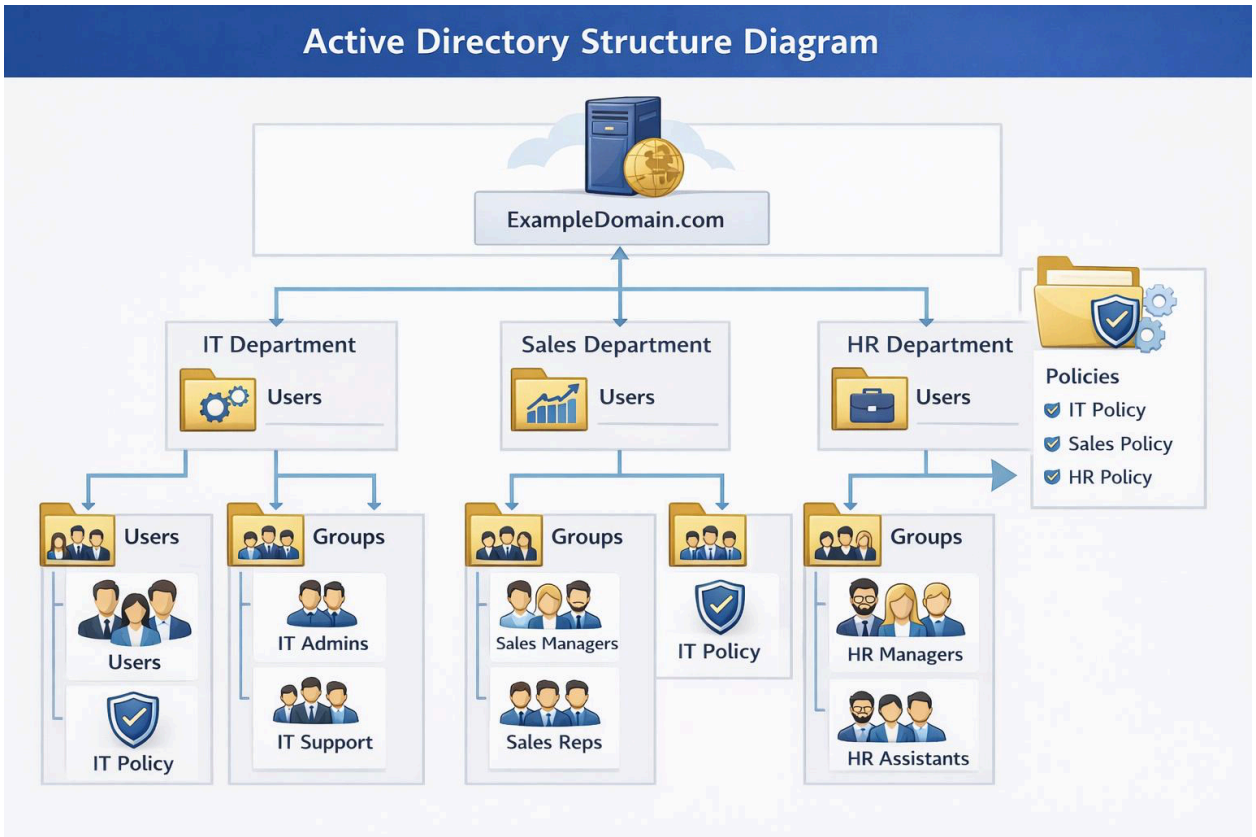


• Project 3 - Zero Trust Architecture: Illustrate identity verification, device validation, and access gateway.



• Project 4 - DDoS Attack Diagram: Show botnet traffic overwhelming a target server.





• Project 5 - Active Directory Structure Diagram: Illustrate domain, organizational units, users, groups, and policies